

AI Impact Maine — ai-policy-template (full)

AI POLICY TEMPLATE FOR SMALL ORGANIZATIONS

Full Professional Version

Document Type: Customizable AI Governance Policy
Audience: Small businesses, nonprofits, municipalities, community organizations
Version: 1.0 | **Last Updated:** May 2026
Estimated Read Time: 30 minutes | **Implementation Time:** 4-6 weeks

🔗 TABLE OF CONTENTS

- 1. Introduction & Executive Summary
 - 2. Scope & Applicability
 - 3. AI Tool Categories & Classification
 - 4. Policy Principles & Values
 - 5. Approved & Prohibited AI Tools
 - 6. Data Security & Privacy Requirements
 - 7. Employee Guidelines & Best Practices
 - 8. Governance & Approval Processes
 - 9. Incident Response & Escalation
 - 10. Implementation Roadmap
 - 11. Policy Appendices
-

SECTION 1: INTRODUCTION & EXECUTIVE SUMMARY

1.1 Purpose of This Policy

This AI Policy establishes guidelines for the safe, responsible, and effective use of artificial intelligence (AI) tools and systems across [Organization Name]. The policy aims to:

- Maximize productivity and decision-making quality
- Protect organizational data, security, and privacy
- Ensure compliance with applicable regulations
- Mitigate AI-related risks and unintended consequences
- Maintain transparency and stakeholder trust
- Promote responsible, ethical AI use
- Support employee skill development and adoption

This policy applies to: All employees, contractors, volunteers, and board members using AI tools for work purposes.

1.2 What is AI? (Simple Definition)

For purposes of this policy, **Artificial Intelligence (AI)** includes: - Large language models (ChatGPT, Claude, Gemini, Copilot, etc.) - Image generators (DALL-E, Midjourney, Stable Diffusion, etc.) - Code assistants (GitHub Copilot, Tabnine, etc.) - Automation and workflow tools (Zapier, Make, n8n with AI features) - Analytics and business intelligence tools using AI - Document analysis and summarization tools - Any other software using machine learning or generative AI

What this policy does NOT cover: - Standard software tools (Slack, email, project management, etc.) - Basic analytics dashboards - Traditional automation tools without AI/ML components - Hardware or IT infrastructure policies

1.3 Why This Policy Matters

Organizations using AI without clear guidelines face risks including: - **Data breach:** Sensitive information accidentally shared with AI services - **Compliance violation:** Regulatory non-compliance (GDPR, HIPAA, FERPA, etc.) - **IP theft:** Intellectual property being used to train AI models - **Reputation risk:** Public backlash from AI misuse - **Bias & fairness:** Discriminatory outcomes from unvetted AI systems - **Productivity loss:** Uncontrolled, inefficient AI adoption

This policy prevents these risks while enabling innovation.

SECTION 2: SCOPE & APPLICABILITY

2.1 Who Must Follow This Policy

This policy applies to: - All full-time and part-time employees - Contractors and consultants - Board members and volunteers - Interns and temporary staff - Partner organizations accessing our systems

2.2 What Systems Are Covered

This policy governs: - AI tools used for **work purposes** on any device (company or personal) - AI tools accessing organizational data - AI tools creating work-related outputs - AI tools integrated into organizational workflows - AI tools used on company networks

Exclusions: Personal, non-work-related AI use on personal devices/networks is not covered.

2.3 Scope of AI Applications

This policy covers AI tools used for: - Content creation (writing, editing, brainstorming) - Code development and technical work - Data analysis and visualization - Customer

interactions and support - Marketing and communications - Decision support and analysis - Administrative and operational tasks - Any other work-related application

SECTION 3: AI TOOL CATEGORIES & CLASSIFICATION

3.1 Tool Classification System

All AI tools are classified by risk level. This determines approval requirements and usage guidelines:

TIER 1: APPROVED (Low Risk)

Definition: Tools with minimal data security risk, clear vendor track records, and appropriate terms of service.

Characteristics: - Vendor has published privacy policy - Data is NOT used for model training - Limited access to sensitive data - Transparent pricing and terms - No unusual data requests - Wide adoption in similar organizations

Examples: - ChatGPT (with proper data handling) - Claude (Anthropic) - Microsoft Copilot Pro - Grammarly (Business plan) - Perplexity AI

Usage: Can be used by any employee with training completion. No approval needed.

TIER 2: RESTRICTED (Medium Risk)

Definition: Tools that provide value but require approval and monitoring due to data security, privacy, or compliance considerations.

Characteristics: - Vendor privacy policy is unclear or concerning - May use data for model improvement - Handles sensitive data - Compliance implications (GDPR, HIPAA, etc.) - Requires specific configuration/settings - Limited track record

Examples: - Image generators (DALL-E, Midjourney) – unless restricted by law - Some industry-specific AI tools - Tools processing financial or health data - Custom or less-established tools - Tools integrating with multiple platforms

Usage: Requires department manager approval and compliance review before use.

TIER 3: PROHIBITED (High Risk)

Definition: Tools that pose unacceptable risks and are not permitted for use.

Characteristics: - No published privacy policy - Clear terms of service abuse - Data used for model training without consent - Regulatory non-compliance - Security vulnerabilities - Reputation risk - Vendor viability concerns

Examples: - Unknown/unvetted AI tools - Tools that explicitly claim to train on user data - Non-compliant tools in regulated environments - Tools with known security vulnerabilities - Tools violating organizational values

Usage: Strictly prohibited. Violators subject to disciplinary action.

3.2 How to Classify a New Tool

When evaluating an unlisted AI tool:

1. **Review the vendor privacy policy** – Does it clearly state data usage?
2. **Check compliance requirements** – Does it meet legal/regulatory needs?
3. **Assess data sensitivity** – What data will it access?
4. **Review terms of service** – Any unusual or concerning clauses?
5. **Check security features** – Encryption, access controls, audit logs?
6. **Research vendor reputation** – User reviews, press coverage, track record?
7. **Evaluate alternatives** – Is there a lower-risk equivalent?
8. **Submit for approval** – Ask IT/Compliance to classify

Use Tool Evaluation Form (Appendix A) to document your assessment.

SECTION 4: POLICY PRINCIPLES & VALUES

4.1 Core Principles

This policy is built on these core principles:

1. *Security First*

- Organizational data and security are paramount
- AI tools must not compromise data protection
- Encrypted transmission and storage required
- Audit trails and access controls essential

2. *Transparency & Disclosure*

- Use of AI in work must be disclosed when appropriate
- Customers/stakeholders notified when AI is used on their behalf
- AI-generated content clearly labeled
- Decision logic made visible

3. *Human Responsibility*

- Humans are accountable for AI outputs
- AI does not replace human judgment on critical decisions
- Humans must review AI outputs for accuracy and bias
- Responsibility cannot be delegated to AI

4. Fairness & Inclusion

- AI tools must not perpetuate bias or discrimination
- Special care required for decisions affecting protected groups
- Diverse perspectives included in AI implementation
- Accessibility standards maintained

5. Privacy Protection

- Personal data protected at all times
- Customer/client privacy respected
- Minimal data collection and retention
- Compliance with privacy laws

6. Continuous Improvement

- Regular policy review and updates
 - Staff feedback incorporated
 - Monitoring of AI risks and benefits
 - Willingness to restrict or ban tools as needed
-

SECTION 5: APPROVED & PROHIBITED TOOLS

5.1 Approved Tools - TIER 1 (No Approval Needed)

Tool Name	Category	Key Features	Data Handling	Notes
ChatGPT (Gpt-4o)	Text/Content	General purpose, chat interface	Data NOT retained for training	Org can opt out of training data usage
Claude (Anthropic)	Text/Content	Analysis, writing, research	Data NOT used for training	High accuracy, long context windows
Google Gemini	Text/Content	Search integration, analysis	Google account required	Data tied to Google account
Microsoft Copilot Pro	Text/Content	Microsoft integration	Microsoft account required	Works within Microsoft ecosystem

Perplexity AI	Research	Web search + AI	Transparent data policy	m Good for research, real-time info
Grammarly (Business)	Writing	Grammar, tone, suggestions	Business plan has privacy protections	Write with confidence
Notion AI	Productivity	Summarization, writing	Notion workspace data	Only within Notion

Important: Even for Tier 1 tools, follow all data handling guidelines in Section 6.

5.2 Restricted Tools – TIER 2 (Approval Required)

Submit these to your manager + compliance team before use:

Tool Name	Category	Why Restricted	Approval Process
DALL-E, Midjourney	Image Gen	Copyright concerns, vendor data use	Manager approval + legal review
Jasper AI	Content	Third-party data handling	Manager + compliance approval
HubSpot AI	Business Tools	Data integration required	Manager + IT review
Industry-specific tools	Varies	Compliance/regulatory concerns	Case-by-case review

5.3 Strictly Prohibited – TIER 3

Any unlisted, unknown, or unapproved AI tool

Tools that claim to train on user data without consent

Tools from companies with known security vulnerabilities

Tools that don't publish privacy policies

Tools violating GDPR, HIPAA, FERPA, or other regulations

SECTION 6: DATA SECURITY & PRIVACY REQUIREMENTS

6.1 Data Classification

Classify all data before using it with AI:

PUBLIC DATA ?

- Already published publicly
- No harm if shared externally
- Examples: General company news, public website content

AI Usage: Can be used freely with Tier 1 approved tools

INTERNAL DATA ⚠

- Not confidential but not public
- Examples: Internal policies, internal emails, general reports

AI Usage: ⚠ Can use with approved tools, with basic safeguards

CONFIDENTIAL DATA ?

- Commercially sensitive information
- Examples: Business plans, pricing, strategy, financial data

AI Usage: Use only with manager approval, restricted tools

RESTRICTED DATA ?

- Personal data, customer data, protected categories
- Examples: Names, SSN, health records, financial accounts, racial/ethnic data

AI Usage: **NEVER share with AI tools.** Anonymize first or use only with explicit compliance approval.

6.2 What Data MUST NEVER Be Shared with AI Tools

Personal Identifiable Information (PII) - Names + identifying information - Social Security Numbers, passport numbers - Driver's license numbers - Bank account numbers, credit card numbers

Health & Medical Information - Patient records - Health conditions - Medical history - Mental health information

Financial Data - Bank account numbers - Credit card numbers - Tax returns - Financial account details

Protected Categories (if containing identifying info) - Racial/ethnic data - Religious affiliation - Sexual orientation - Immigration status - Disability information - Genetic data

Customer/Client Data (names + sensitive info) - Customer names with financial/health data - Client contracts with proprietary terms - Subscriber/donor lists with amounts

Passwords, Keys, Credentials - API keys - SSH keys - Database credentials - OAuth tokens - Private keys

If data falls into any of these categories, DO NOT USE WITH AI.

6.3 Safe Ways to Use AI with Sensitive Data

Option A: Anonymize/De-identify First - Remove identifying information - Replace names with “Person A,” “Person B” - Replace specific numbers with ranges (“between 100-500”) - Remove dates that identify individuals

Example: “Customer Jennifer Smith from Maine, age 34, diagnosed with diabetes, spent \$2000/month”

“Older adult customer from Northeast region, chronic condition, spending \$2000-3000/month range”

Option B: Use Only Internal Approved Tools - For highly sensitive data, use only tools your org has vetted - Examples: Org-hosted models, enterprise-licensed tools with DPA

Option C: Work with Blanked Data - Remove the sensitive element entirely - Example: Share survey insights without demographic breakdowns

Option D: Request Manager/Legal Approval - For critical business needs, manager + legal can approve case-by-case - Document the approval - Implement additional safeguards

6.4 Privacy Safeguards When Using AI

Even with approved, non-sensitive data:

- Use tools explicitly designed for enterprise privacy
- Enable two-factor authentication (2FA)
- Use strong, unique passwords
- Don't share login credentials
- Review the vendor's privacy policy before first use
- Check if data is retained or used for training
- Delete conversations containing any sensitive info after use
- Use incognito/private browsing if using personal accounts
- Don't save outputs containing sensitive data to cloud storage
- Be cautious with open office/screen sharing when using AI

6.5 Data Retention & Deletion

For approved tools using non-sensitive data: - Review vendor data retention policies - Many tools delete data after 30-90 days - Verify this before using

For conversations with sensitive data (even anonymized): - Manually delete chat histories - Don't rely on auto-deletion - Use secure deletion (not just trash bin)

For AI-generated content: - Keep version history and source data - Audit trail of how content was created - Be prepared to explain AI involvement

SECTION 7: EMPLOYEE GUIDELINES & BEST PRACTICES

7.1 Before You Use an AI Tool

1. ☒ **Check if it's approved** – Is it Tier 1 or have you gotten Tier 2 approval?
2. ☒ **Classify your data** – Is it public, internal, or confidential?
3. ☒ **Read privacy policy** – How does vendor handle data?
4. ☒ **Complete training** (if your org requires it)
5. ☒ **Get manager approval** (if needed for your use case)

7.2 While Using AI Tools

DO: - Review AI outputs for accuracy before using - Check for hallucinations or “made-up” information - Verify data and citations - Use AI to enhance your work, not replace thinking - Disclose AI use in appropriate contexts - Label AI-generated content - Ask for help if unsure about a use case - Report problems or security concerns

DON'T: - Share confidential data without approval - Share PII, health info, or financial data - Treat AI outputs as authoritative without verification - Use AI to make critical decisions without human review - Plagiarize AI outputs as human work - Use prohibited tools - Ignore suspicious vendor practices - Assume AI understands context or nuance

7.3 AI Use for Common Tasks

Writing & Content Creation

Use Case: Blog posts, emails, social media, reports

Best Practices: - Use AI to brainstorm ideas, draft outlines - Have AI generate drafts you then edit - Verify all facts and citations - Add personal voice and expertise - Disclose AI assistance if writing for public

Don't Do This: - Copy AI output verbatim without review - Use AI to plagiarize competitor content - Mislead audience about authorship - Share customer/client data for writing help

Code Development

Use Case: Code generation, debugging, learning

Best Practices: - Use AI to accelerate development, not replace expertise - Always review generated code for security issues - Test thoroughly before deployment - Verify licensing (ensure open source compliance) - Document any AI-assisted code

Don't Do This: - Trust AI code without security review - Deploy code you don't understand - Use AI to generate code without vendor compliance check - Share proprietary code for analysis

Data Analysis & Research

Use Case: Summarizing documents, analyzing trends, research assistance

Best Practices: - Use AI to accelerate research, not replace it - Verify AI-generated insights with primary sources - Check for bias in analysis - Validate numbers and statistics - Use as starting point for deeper research

Don't Do This: - Trust AI analysis without validation - Skip primary sources - Share customer/research data - Use AI findings without fact-checking

Customer Communication

Use Case: Email drafts, support responses, FAQs

Best Practices: - Use AI to draft initial responses - Personalize and review before sending - Verify all information is accurate - Disclose AI assistance if appropriate - Protect customer privacy

Don't Do This: - Send generic AI responses without personalization - Share customer data or feedback with AI - Use AI for sensitive customer issues without human review

SECTION 8: GOVERNANCE & APPROVAL PROCESSES

8.1 Approval Structure

For TIER 1 (Approved) Tools: - No approval needed - Recommended: Manager notification - Required: Complete training module

For TIER 2 (Restricted) Tools: - Manager approval required (email/Slack approval acceptable) - Compliance review (if data is sensitive) - Document approval in Tool Approval Log (Appendix B) - Follow additional safeguards

For TIER 3 (Prohibited) Tools: - No approval possible - Violators subject to discipline - Report suspected use to [Compliance Officer]

8.2 Tool Approval Request Form (For Tier 2)

Template for requesting approval of restricted tools:

TO: [Manager Name] / [Compliance Officer]

TOOL REQUEST:

Tool Name: _____

Vendor: _____

Website: _____

USE CASE:

What will you use this tool for?

What data will you access?

☐ Public

- ☐ Internal
- ☐ Confidential
- ☐ Restricted (PII/Health/Finance)

VENDOR REVIEW:

- ☐ Privacy policy reviewed (attach summary)
- ☐ Terms of service reviewed
- ☐ Security features verified
- ☐ Compliance requirements checked

BUSINESS CASE:

Why do you need this tool?

What's the expected benefit?

Are there alternative Tier 1 tools?

REQUESTER:

Name: _____ Date: ____

Department: _____

Manager: _____

APPROVAL:

- ☐ Approved by: _____ (Manager)
- ☐ Approved by: _____ (Compliance)
- ☐ Denied. Reason: _____

8.3 Ongoing Monitoring & Audits

Quarterly Reviews: - Review approved tool usage - Monitor for policy violations - Check vendor security updates - Assess tool effectiveness

Annual Audits: - Full compliance audit - Tool re-evaluation (Tier 2) - Policy effectiveness review - Update policy as needed

Incident Triggers: - Security incident or data breach - Vendor privacy policy change - Regulatory requirement change - New tools with concerning practices

SECTION 9: INCIDENT RESPONSE & ESCALATION

9.1 What Constitutes a Policy Violation

- Using prohibited (Tier 3) tools
- Sharing restricted data (PII, health, financial) with any AI tool
- Using Tier 2 tools without approval

- Failure to disclose AI use when required
- Downloading/storing AI outputs containing sensitive data
- Deliberately circumventing this policy

9.2 Reporting a Violation

If you suspect a violation:

1. **Report to your manager** (for initial issues/education)
2. **Report to [Compliance Officer]** (for serious violations)
3. **Report to [Security Team]** (for data breach concerns)
4. **Anonymous hotline:** [Phone/Email] (if needed)

No retaliation policy: Employees reporting in good faith are protected.

9.3 Investigation Process

When a violation is reported:

1. **Immediate assessment** – Is there a data security risk?
2. **Evidence gathering** – Review usage, data access, communications
3. **Notification** – Inform employee of investigation
4. **Interview** – Opportunity for employee to explain
5. **Determination** – Substantiated or not substantiated
6. **Documentation** – Record outcome and actions taken
7. **Remediation** – If substantiated, address the issue

9.4 Disciplinary Actions

For unintentional violations (first offense): - Coaching/training - Tool access revoked - Additional monitoring

For repeated violations: - Written warning - Tool restrictions - Discipline up to termination (depending on severity)

For serious violations (data breach, prohibited tool use): - Immediate investigation - Potential termination - Legal/compliance escalation

9.5 Data Breach Response

If AI tool breach occurs:

1. **Immediately notify [Security Officer]**
2. **Take tool offline** (remove access)
3. **Preserve evidence** (don't delete data)
4. **Assess scope** – What data was exposed?
5. **Notify affected parties** (customers, regulators if required)
6. **Root cause analysis** – How did it happen?

7. **Remediation** – Fix the issue
 8. **Communication** – Update staff on changes
-

SECTION 10: IMPLEMENTATION ROADMAP

Phase 1: Preparation (Week 1-2)

Tasks: - ☒ Get leadership approval of policy - ☒ Assign policy owner/compliance lead - ☒ Create Approved Tools List (Appendix C) - ☒ Review current AI tool usage (audit) - ☒ Set up approval process/form - ☒ Identify training needs

Deliverables: - Policy officially adopted - Approval process documented - Current AI usage inventory

Phase 2: Communication (Week 3-4)

Tasks: - ☒ Launch policy with all-staff announcement - ☒ Host Q&A session (live or recorded) - ☒ Create policy summary/one-pager - ☒ Post policy on intranet/shared drive - ☒ Assign training modules - ☒ Set up FAQ/help desk support

Deliverables: - 100% staff awareness - Training completion: 80%+ - FAQ documentation

Phase 3: Implementation (Week 5-8)

Tasks: - ☒ Begin approval process for any Tier 2 tools - ☒ Establish tool inventory/tracking - ☒ Complete training for all staff - ☒ Establish monitoring processes - ☒ Create incident reporting channels - ☒ Set up quarterly review schedule

Deliverables: - All pending tool requests processed - Tool inventory documented - Monitoring processes operational

Phase 4: Optimization (Ongoing)

Tasks: - ☒ Monthly check-ins on policy effectiveness - ☒ Quarterly tool review (approve new ones, restrict as needed) - ☒ Annual full policy review - ☒ Update policy based on feedback - ☒ Train new hires on policy - ☒ Track metrics (adoption, violations, incidents)

Deliverables: - Policy continuously updated - Staff feedback incorporated - Metrics tracked and reported

APPENDIX A: TOOL EVALUATION FORM

Use this form to assess new AI tools:

TOOL EVALUATION CHECKLIST

Tool Name: _____ Date: _____
Evaluated By: _____ Dept: _____

VENDOR VERIFICATION

- ☐ Company website accessible
- ☐ Clear privacy policy available
- ☐ Terms of service reviewed
- ☐ Contact information available
- ☐ Company financially stable
- ☐ Track record verified

PRIVACY & SECURITY

- ☐ Privacy policy is clear and comprehensive
- ☐ Data NOT used to train models (or opt-out available)
- ☐ Data encrypted in transit and at rest
- ☐ Complies with GDPR (if applicable)
- ☐ Complies with CCPA (if applicable)
- ☐ Complies with HIPAA (if handling health data)
- ☐ Complies with FERPA (if in education)
- ☐ Regular security audits (SOC 2 or equivalent)
- ☐ Breach notification policy documented
- ☐ Data deletion policy clear

DATA HANDLING

- ☐ Clear data retention policy
- ☐ User can access own data
- ☐ User can delete own data
- ☐ No sharing with third parties (except necessary)
- ☐ Subprocessors listed and vetted

FUNCTIONALITY

- ☐ Meets stated use case needs
- ☐ Ease of use is appropriate
- ☐ Integration options available
- ☐ Customer support adequate
- ☐ Pricing is reasonable
- ☐ No major competing tools are better

RISK ASSESSMENT

Risk Level: ☐ Low (Tier 1) ☐ Medium (Tier 2) ☐ High (Tier 3)

Risks Identified: _____

Mitigation strategies: _____

RECOMMENDATION

- ☐ APPROVED (Tier 1 - No approval needed)
- ☐ APPROVED WITH RESTRICTIONS (Tier 2 - Manager approval needed)
- ☐ NOT APPROVED (Tier 3 - Prohibited)

Reason: _____

Approved By: _____ Date: _____

APPENDIX B: TOOL APPROVAL LOG

Track all approvals and decisions:

Date	Tool Name
------	-----------

APPENDIX C: APPROVED TOOLS LIST

Keep this updated and share with staff:

TIER 1: Approved (No Approval Needed)

- ChatGPT (OpenAI)
- Claude (Anthropic)
- Google Gemini
- Microsoft Copilot Pro
- [Add your org's approved tools]

TIER 2: Restricted (Approval Required)

- [Document any Tier 2 tools your org approves]
-

APPENDIX D: SAMPLE DISCLOSURE LANGUAGE

Use this language when disclosing AI use to stakeholders:

For Customer Communications:

“This email was drafted with assistance from an AI writing tool and reviewed by our team for accuracy.”

For Marketing Materials:

“This article was created with research assistance from AI, then written and fact-checked by our team.”

For Code/Deliverables:

“This code includes sections generated by AI development tools, fully reviewed and tested by our engineering team.”

Document Control

Version: 1.0

Last Updated: May 2026

Next Review: May 2027

Owner: [Policy Owner Name]

Contact: [Email/Phone]

Questions about this policy?

Contact: [Compliance Officer Name]

Email: [Email Address]

Schedule a consultation: [Link]

This policy is a template. Customize all bracketed sections for your organization.